



Cybersecurity in critical rail infrastructure: sector specific adoption of the NIS 2 directive in Europe

Mimi Enakome Oka¹ · Martin Hromada¹ · Roman Jasek¹

Received: 14 January 2026 / Accepted: 8 April 2026
© The Author(s) 2026

Abstract

The Network information systems (NIS) 2 directive was introduced to strengthen cybersecurity obligations for operators of essential and important services. The critical rail infrastructure falls under essential services; therefore, this study examines how critical rail infrastructure operators are adopting and operationalising NIS 2 directives and identifies the sector-specific challenges that affect their compliance efforts. Using a qualitative document analysis of key European Union Agency for Cybersecurity (ENISA) reports, supported by inductive and deductive coding of NIS 2 directive and Critical Entities Resilience (CER) directive, the research explores four themes: governance fragmentation, uneven cybersecurity maturity, particularly within the Operations Technology (OT) environments, supplier dependency and supply-chain vulnerabilities, and persistent incident reporting and detection gaps. Findings indicate that while the critical rail infrastructure has made progress in adopting NIS 2, its implementation remains partial and inconsistent across Member States and actors. Governance fragmentation hinders knowledge sharing and coordinated response horizontally; variability in IT–OT maturity constrains comprehensive risk management; supply-chain complexity exposes operators to cascading vulnerabilities; and the quality and completeness of incident reporting continues to challenge full compliance with Article 23. When compared with ENISA’s technical implementation guidance, these findings reveal that NIS 2 provides a practical guide for strengthening critical rail infrastructure resilience, but significant operational, organisational, and supply-chain barriers must still be addressed. The study contributes to ongoing critical infrastructure cybersecurity discourse by answering three research questions related to NIS 2 adoption, alignment of publicly available documentation, and sector-specific compliance challenges. It provides a structured evidence base that can support regulators, operators, and suppliers in translating NIS 2 obligations into realistic, sector-appropriate practices that enhance the cybersecurity European critical rail infrastructure.

Extended author information available on the last page of the article

Published online: 18 April 2026

Springer

Keywords Critical rail infrastructure · NIS 2 directives · CER directives · Cyber Resilience ACT (CRA) · ENISA · Risk assessment · Compliance · Governance

Introduction

Transport infrastructure plays a major role in driving global economic activity, narrowing wealth disparities, improving social welfare, reducing business costs, and saving time moving from one place to the other (Cigu et al. 2018).

Intelligent Transport Systems (ITS) rely on artificial intelligence to be more efficient, thereby making the transport infrastructure susceptible to cyber-attacks which can cause major disruptions and compromise passenger safety, resulting in significant financial and legal liabilities (Harvey and Kumar 2020).

Critical rail infrastructures are vulnerable to cyber-attacks because of fragmented governance and their unique operational challenges; legacy infrastructure, the coexistence of IT and OT systems (Mattioli et al. 2020). In response to escalating cyber risks, the European Union adopted the NIS 2 directive (2022/2555) (European Parliament and of the Council 2022) to enhance cybersecurity resilience across essential and important entities (Kun 2025).

While the directive establishes a framework, its practical adoption within the critical rail infrastructure remains insufficiently examined in academic research. Existing literature on the NIS 2 directive has primarily focused on conceptual interpretations, legal analysis, or its limitations with few studies assessing how individual sectors operationalise NIS 2 directives (Ruohonen 2024).

To address this gap, this paper examines the sector-specific adoption of the NIS 2 directive within European critical rail infrastructure through document analysis. By analysing regulatory frameworks and ENISA reports, the study provides practical insights into how critical rail infrastructure operators interpret and respond to NIS 2 directives.

This research paper contributes to ongoing discourse by assessing the propensity of NIS 2 in the critical rail infrastructure. Beyond clarifying current adoption levels, the findings highlight persistent challenges, including legacy system constraints, interoperability issues, dependency on external vendors, and the complexity of integrating cybersecurity obligations with safety-critical operations. The study concludes with practical recommendations for critical rail infrastructure operators aimed at strengthening cybersecurity and improving compliance with NIS 2 directives.

The research papers answer the following research questions.

RQ1: How is the critical rail infrastructure adopting and operationalising the requirements of the NIS 2 directive?

RQ2: In what ways do rail-sector documents align with the NIS 2 risk management and incident reporting requirements?

RQ3: What sector-specific challenges influence the critical rail infrastructure ability to achieve effective NIS 2 compliance?

Literature review

Cybersecurity landscape of critical rail infrastructure

The digitisation and automation of processes in the critical rail infrastructure have led to major transformations in its operations introducing new challenges and risks (Zgorzelski et al. 2025). Modern critical rail infrastructure relies on a complex ecosystem of digital assets, including signalling systems, supervisory control and data acquisition (SCADA) platforms, telecommunication networks, passenger information systems, and integrated ticketing solutions (Predescu et al. 2022) increasing the cyber risk.

Security is often considered as an after-thought in the design process in critical rail infrastructure due to business strategic objectives, increasing the likelihood of a successful attack (Soderi et al. 2023), also the poor traceability to a particular attacker makes it a favourable target for different attackers (Gabriel et al. 2018).

Assets in critical rail infrastructure are designed to last for decades but cyber threats are constantly evolving making current measures inadequate throughout an asset's 30-year lifespan. There is a lack of comprehensive, real-time cybersecurity framework tailored to their specific needs, most of the frameworks are deficient in their capacity to adapt effectively to emerging threats, particularly where legacy systems are present alongside novel technologies (Ibadah et al. 2024) (Zgorzelski et al. 2025). These are some of the limitations the sector faces.

From the above, it is important to note that cybersecurity in the critical rail infrastructure is not merely a technical problem but a fundamental component of national security, passenger safety, and critical infrastructure resilience.

EU regulatory framework for critical rail infrastructure cybersecurity

In response to the evolving cyber threat, the European Union established the NIS 2 Directive EU 2022/2555. It forms the cornerstone of the EU's cybersecurity strategy, introducing more stringent risk management all hazard approach obligations, enhanced incident reporting requirements, and supply chain responsibilities for essential and important entities. Under NIS 2, essential entities must adopt appropriate and proportionate technical, operational and organisational measures to manage risk posed to the security of network and information systems to prevent or minimise the impact of incidents that are recipients of their services (European Parliament and of the Council 2022; Kun 2025).

Critical entities play a key role in the maintenance and functions of economic activities in society (Zgorzelski et al. 2025). According to this definition, the critical rail infrastructure falls under the category of critical entities and therefore is subject to the CER directive. The NIS 2 directive, which imposes a large set of requirements on the cybersecurity of essential and important entities, complements the CER directive which emphasises physical and operational resilience. There is regulatory overlap between NIS 2 and CER, in areas of risk assessment, resilience planning, and incident management. However, they should be implemented in a mutually beneficial

manner in critical rail infrastructure such that they do not become an administrative burden to the entity (European Parliament, Council of the European Union 2022).

The Cyber Resilience Act (CRA) introduces a comprehensive regulatory framework designed to enhance the security of hardware and software products with digital elements throughout their entire lifecycle. Its core objective is to reduce systemic vulnerabilities by ensuring that manufacturers integrate cybersecurity considerations from the design phase through to development, deployment, and ongoing maintenance. By mandating stringent obligations related to secure-by-design principles, vulnerability handling, and continuous risk management, the CRA strengthens cybersecurity assurance across supply chains and promotes greater accountability among manufacturers. As a result, the directive is expected to play a significant role in improving supply chain security and elevating the overall resilience of digital products within the European market (Regulation (EU) 2024). Although this is not specific to the critical rail infrastructure, it is applicable to the hardware and software integrated into intelligent rail systems. These new technologies, many of which are commercial off the shelf (COTS) have increased the chances of exposure to a cyber-attack (Parkinson et al. n.d).

Alongside EU legislation, sector-specific standards such as CENELEC TS 50701 provide technical frameworks for securing critical rail infrastructure specifically tailored to rail operations and OT systems (Parkinson et al. n.d). However, researchers note that translating these standards into operational routines remains challenging due to financial cost, inability to adequately measure the consequences for risk assessment purposes, insufficient knowledge of the risk of not implementing cybersecurity measures and the cost of an incident if it were to occur (Parkinson et al. n.d) (Zgorzelski et al. 2025).

Collectively, the EU's regulatory ecosystem is evolving toward comprehensive and harmonised cybersecurity governance. However, there are fewer literatures with harmonised sector-specific adoption in critical rail infrastructure, highlighting the need for targeted empirical studies.

Sector-specific adoption challenges in critical rail infrastructure

While regulatory frameworks provide high-level obligations, their practical adoption in critical rail infrastructure remains uneven and under-studied. Literature reveals several structural, organisational, technical, and cultural barriers to implementation (Zgorzelski et al. 2025).

One major concern highlighted is the ageing infrastructure and legacy systems that characterise critical rail infrastructure. Most of these existing systems are legacy systems, which were not designed with the modern cyber security in mind (Parkinson et al. n.d). Integrating NIS 2 directives into these systems poses significant technical and financial challenges as operators are required to balance cybersecurity requirements with operational constraints and business needs. These challenges are further compounded by the sector's reliance on multiple stakeholders and external providers that operate with different technical standards and levels of cybersecurity capability (Predescu et al. 2022).

In addition, scholars increasingly emphasise that human and organisational factors significantly hinder effective NIS 2 implementation in the critical rail infrastructure. Existing training programs are often inconsistent, overly general, or insufficiently tailored to the complexities of critical rail infrastructure. Many operational staff with substantial experience in traditional rail systems may have limited exposure to cybersecurity principles (Zgorzelski et al. 2025) and may perceive new cyber-related procedures as disruptive and overly bureaucratic (Ibadah et al. 2024). There are also challenges in recruiting and maintaining cybersecurity personnels (European Union Agency for Cybersecurity (ENISA), 2025). Studies have shown that many critical rail infrastructure operators lack adequate incident monitoring capabilities, unified reporting systems, or clear internal procedures for escalating incidents (Ibadah et al. 2024).

Another critical challenge is governance fragmentation, critical rail infrastructure involves multiple stakeholders including infrastructure managers, rail undertakings, maintenance contractors, equipment manufacturers, supply chain partners, regulatory authorities, and IT/OT suppliers, each operating with different cybersecurity maturity systems and limited visibility into one another's systems. This fragmentation complicates effective supply chain security management and undermines the consistent implementation of cybersecurity controls across critical rail infrastructure (Ibadah et al. 2024) (Network et al. 2020).

From the above, we can deduce that applying regulatory directives in critical rail infrastructure should not be a box ticking exercise but a socio-technical transformation requiring coordinated effort, sustained investment, and tailored implementation strategies.

Conceptual gaps and the need for sector-specific adoption research

Despite growing scholarly articles, there is a shortage of empirical research examining how stakeholders in critical rail infrastructure practically implement NIS 2 directives (Ruohonen 2024). Many literatures describe the regulatory requirements with fewer investigating the adoption processes within specific sectors. ENISA has produced a guide for the practical implementation of NIS 2; however, it is generic and not specific to critical rail infrastructure (European Union Agency for Cybersecurity 2026).

These gaps highlight the need for targeted empirical studies using document analysis. Understanding how critical rail infrastructure interprets and operationalise regulatory obligations is essential for advancing academic knowledge and informing policymakers. This study therefore contributes to the field by providing real world sector-specific analysis of NIS 2 adoption in critical rail infrastructure.

Methodology

Research design

This study adopts a qualitative research design to examine sector-specific adoption of the NIS 2 directives within the European critical rail infrastructure. A qualitative approach was appropriated because this research seeks to understand how regulatory obligations are interpreted and operationalised in a complex socio-technical environment. Since NIS 2 implementation remains at an early stage across much of Europe, empirical datasets are limited, making document analysis the most suitable methodological tools for capturing emerging patterns, institutional behaviour, and practical barriers.

Document analysis

This method employs the examination of regulatory materials relevant to cybersecurity governance in critical rail infrastructure. Documents were coded thematically using categories derived from the research questions: sector-specific adoption, incident reporting and governance, supply chain and vendor dependencies, organisational/human factors, and compliance challenges. This systematic coding enabled identification of cross-cutting themes, regulatory gaps, and consistent patterns across sources.

Analytical procedure

This study employs a qualitative document analysis (QDA) to examine how European rail infrastructure operators interpret and operationalise the requirements of the NIS 2 directive. QDA was selected because it enables the empirical investigation of existing regulatory texts, technical guidance, and sector-specific cybersecurity reports, allowing patterns, meaning, and regulatory alignment to be systematically extracted from real-world material. As critical rail infrastructure operators do not publish internal cybersecurity documentation, publicly available ENISA reports represent the most reliable empirical evidence base for understanding current practices within European critical rail infrastructure.

The analysis followed a combined inductive–deductive manual coding strategy. This approach allowed sector-specific insights to emerge from the documents while ensuring structured alignment with NIS 2's legally mandated requirements, particularly Articles 21 (cybersecurity risk management and resilience) and 23 (incident reporting). The overall coding and interpretation followed an iterative process in which documents were read multiple times, codes defined, refined, and categories compared across sources to ensure analytical consistency.

Inductive coding procedure

Inductive coding was used to capture themes emerging directly from the material without being limited to predefined regulatory categories. The four selected ENISA

documents are; ENISA Good Railway Practices in Cyber Risk (European Union Agency for Cybersecurity 2021), ENISA Threat Landscape for Supply Chain Attacks (European Union Agency for Cybersecurity (ENISA), 2021), ENISA Railway Cybersecurity (European Network and Information Security Agency et al. 2020), ENISA Transport Threat Landscape (European Union Agency for Cybersecurity 2021). These documents were selected because they provide technical, operational, and organisational insights into cybersecurity posture and challenges within European critical rail infrastructure.

The inductive coding process began with full readings of each document to achieve familiarity with content. During this initial stage, sentences containing relevant information referring to cybersecurity practices, governance structures, operational constraints, human factors, supply-chain issues, incident handling, and risk management were highlighted. For each of the ENISA documents, a minimum of twenty (20) sentences, making a total of eighty (80) sentences were highlighted, copied and pasted to a word document under heading labeled excerpts. These excerpts were applied different codes depending on the topic they addressed in implementing NIS 2 e.g., reporting barrier, supply chain vulnerability, cybersecurity maturity level, and different stakeholders. These codes were compared across all four documents to identify recurring themes. These reoccurring themes were refined into four, government fragmentation, uneven cybersecurity maturity level, incident detection, classification and reporting barriers and supply chain dependency and vulnerability. These themes reflect operational realities and contextual challenges that are not explicitly defined in the NIS 2 directive but significantly influence its practical implementation within critical rail infrastructure. The inductive phase therefore allowed the study to surface issues grounded in real operational settings that extend beyond regulatory text.

Deductive coding procedure

To complement the emergent inductive themes, deductive coding was applied to systematically assess alignment with the explicit cybersecurity obligations set out in NIS 2 Articles 21(risk management) and 23 (incident reporting), alongside relevant elements of the Critical Entities Resilience Directive (CER). A predefined coding framework was developed based on these articles, covering five regulatory domains: risk analysis, incident prevention/detection, supply-chain security, business continuity and resilience, and incident notification timelines.

The highlighted twenty (20) sentences labeled excerpts on each of the four ENISA documents were re-examined through this deductive lens. Eighty (80) excerpts in total were compared with the requirements of NIS 2 to reflect their alignment with risk analysis, incident prevention/detection, supply-chain security, business continuity and resilience, and incident notification timelines and then coded with one of the following statements: aligned, partially implemented, revealed implementation gaps.

This structured assessment allowed direct comparison between regulatory expectations and sector practices, making it visible where critical rail infrastructure aligns with, exceeds, or falls short of NIS 2 obligations.

Iterative integration

Codes were reviewed across multiple cycles to ensure coherence between emerging sector-specific themes and the predefined regulatory categories. This iterative integration provided a robust analytical basis for the findings, enabling the study to distinguish between implementation challenges arising from operational realities and challenges arising from regulatory misalignment or incomplete adoption of NIS 2 requirements.

Ethical considerations

The research uses exclusively publicly accessible materials and does not involve human participants. Therefore, the study does not require formal ethical approval.

Limitations

This methodology is subject to several limitations. First, the absence of primary interviews limits the study's ability to capture internal organisational perspectives on compliance strategies and operational challenges. Second, reliance on publicly available documents means that the depth of analysis may not fully reflect internal cybersecurity practices. Third, the lack of publicly documented post NIS 2 implementation cyber incidents within the European critical rail infrastructure restricts opportunities to examine real-world responses under the new directive. Thirdly, a few samples were chosen to manage the manual coding that was used for the analysis. Despite these constraints, the document-analysis design provides a sufficiently robust foundation for evaluating how critical rail infrastructure has implemented NIS 2 directive.

Results/findings

The assessment showed four interrelated findings that explain how regulatory expectations translate into practice within European critical rail infrastructure.

Governance fragmentation and its impact on risk management (article 21)

Both inductive and deductive analyses consistently identify governance fragmentation as a fundamental barrier to effective NIS 2 implementation in critical rail infrastructure. Inductive coding highlights the involvement of multiple interdependent stakeholders including infrastructure managers, rail undertakings, suppliers, and authorities with differing cybersecurity maturity levels and limited visibility into one another's systems. This was reflected in coded excerpts such as ENISA's Cybersecurity Good Practices (European Union Agency for Cybersecurity 2021) observation that "*the railway sector comprises of multiple stakeholders who are responsible for their own infrastructure, assets and services...*" illustrating the sector-wide lack of cohesive oversight.

While NIS 2 establishes mandatory incident reporting to national competent authorities, governance fragmentation within critical rail infrastructure constrains broader information sharing among stakeholders. Several ENISA reports note that details on attack techniques and incident handling are rarely shared outside the directly affected organisation. This was deduced from ENISA (European Union Agency for Cybersecurity 2021) excerpt *“important information on technical explanation as to how the attackers obtained access to the targets are often missing. This describes the security posture of the victim organisation, so it is hidden from the public”* a finding coded under limited cross-organisational learning. This results in isolated learning and limited collective situational awareness at sector level. Thus, compliance with Article 21’s formal requirements does not automatically translate into coordinated or harmonised security practices.

From a deductive perspective, this fragmentation directly challenges Article 21’s requirement for coordinated organisational and technical risk-management measures. ENISA documents highlight that rail entities apply heterogeneous risk-management frameworks, noting that risk assessment practices vary significantly across operators, depending on national rules and internal capabilities. Excerpt from European Union Agency for Cybersecurity (2021) *“many definitions and concepts of risk management exist, thus making it difficult to choose that which is most relevant to an organisation”*.

When viewed deductively, these disparities illustrate partial implementation of Article 21 rather than the absence of compliance.

Uneven cybersecurity maturity and implementation across the rail sector (article 21)

Inductive coding shows that uneven cybersecurity maturity persists across operators, suppliers, and Member States. ENISA document (European Union Agency for Cybersecurity 2021) stated that *“enforcing minimum baseline requirements is risky as the minimum baseline do not change while the threat landscape changes, also these minimum-security requirements do not meet the risks of organisations.”* a coded excerpt demonstrating the variation in technical and organisational capabilities. This uneven maturity is especially apparent in cross-border critical rail infrastructure, where operators must comply with multiple national transpositions of NIS 2, creating regulatory and operational complexity.

Deductive coding reinforces this pattern by showing that uneven maturity limits full alignment with Article 21. For example, ENISA (European Union Agency for Cybersecurity 2021) notes that *“adaptation of legacy systems should be considered as a priority, considering the complexity of updating OT systems with long lifecycles.”* a coded excerpt illustrating structural rather than regulatory limitations. These constraints indicate that while policies and procedures exist on paper, effective implementation remains partial due to workforce shortages, resource limitations, and the long lifecycle of critical rail infrastructure OT systems. This demonstrates that gaps in Article 21 implementation stem more from operational constraints than non-compliance.

Incident detection, classification, and reporting challenges (article 23)

Inductive findings reveal persistent challenges in incident detection and reporting. ENISA (European Union Agency for Cybersecurity (ENISA) (2021)) reports describe situations where *“cyber-attacks lunched may take months to be successful and, in many cases, go undetected for a long time”* which was coded under delayed detection. Additionally, ENISA (European Union Agency for Cybersecurity (2021)) highlights that *“operators often handle early-stage incidents internally without immediate escalation,”* reflecting concerns over reputational impact and uncertainty about reportability thresholds.

Deductive analysis against Article 23 demonstrates that the issue is not a lack of awareness of mandatory reporting timelines, but the difficulty of meeting them in practice. ENISA (European Network and Information Security Agency et al. 2020; European Union Agency for Cybersecurity (ENISA) (2021),) that *“organisations struggle to classify complex incidents, especially when cascading or cross-border effects cannot be assessed quickly,”* a coded excerpt showing challenges with early warning and notification. Despite improving reporting maturity, inconsistencies in data quality driven by IT/OT fragmentation, legacy technologies, and supplier-managed assets continue to constrain the effectiveness of Article 23 compliance. As a result, early warnings and follow-up reports may meet formal deadlines but offer limited actionable insight, reducing their value for systemic risk mitigation.

Supplier dependency and supply-chain vulnerability (article 21 and CER interface)

The most prominent cross-cutting finding is supplier dependency and related supply-chain vulnerability. Inductive coding shows that critical rail infrastructure operators rely extensively on third parties for asset maintenance, patching, threat intelligence, and lifecycle support. ENISA (European Union Agency for Cybersecurity (ENISA) (2021)) documents emphasise that *“security capabilities differ widely between suppliers, and operators often lack visibility into the cybersecurity posture of vendor-provided components,”* a coded excerpt highlighting structural dependency risks.

Deductive findings show that this dependency significantly complicates Article 21's requirements for supply-chain security. ENISA (European Union Agency for Cybersecurity (ENISA) (2021)) notes that *“organisations could be vulnerable to a supply chain external attack even when its own defences are quite good as attackers try to explore potential ways to infiltrate them”* indicating that operators' compliance is influenced by external parties they do not fully control. Furthermore, the interconnected nature of critical rail infrastructure supply chains creates the potential for cascading failures with national or cross-border implications placing the issue at the intersection of NIS 2, the CER Directive, and the Cyber Resilience Act (CRA).

Although NIS 2 mandates supplier risk management, CER requires continuity planning, and the CRA introduces security obligations for manufacturers, ENISA reports that critical rail infrastructure operators have yet to integrate these requirements effectively. However, ENISA (European Union Agency for Cybersecurity (ENISA) (2021)) observes that *“resilience planning in critical rail infrastructure*

predominantly centers on physical disruptions, with cyber-related supplier failures less integrated into continuity procedures,”. This coded excerpt highlights a misalignment between regulatory expectation and current practice, signalling for a better integration of NIS 2, CER, and CRA requirements within critical rail infrastructure resilience strategies.

Synthesis of findings

Taken together, the integrated inductive and deductive findings indicate that NIS 2 implementation in European critical rail infrastructure is shaped less by regulatory gaps and more by structural, organisational, and technical constraints. Governance fragmentation, uneven maturity, detection and reporting challenges, and supplier dependency collectively limit the consistent application of Articles 21 and 23. The addition of coded excerpts from ENISA documents reinforces that observed challenges are grounded in documented sector behaviour rather than theoretical assumptions. Overall, the findings suggest that effective sector-specific adoption of NIS 2 requires not only legal transposition but also harmonised operational practices, enhanced cross-organisational coordination, and deeper integration of cybersecurity into critical rail infrastructure-specific resilience frameworks.

Backbone mapping of NIS 2 obligations to critical rail infrastructure practice

To consolidate the thematic findings and provide a structured comparison between NIS 2 obligations and current practices within European critical rail infrastructure, a backbone mapping tables was developed (Table 1 and 2). These tables synthesises both the inductive insights that emerged from the ENISA documents and the deductively derived requirements of Articles 21 and 23 of NIS 2. For each sub-obligation under the NIS 2 directive, the table outlines the observed status in critical rail infrastructure, identifies specific implementation gaps, and proposes targeted mitigation measures. These are further contextualised with reference to complementary regulatory and technical frameworks, including the Cyber Resilience Act (CRA), the Critical Entities Resilience Directive (CER), ENISA documents, and CENELEC TS 50701. The table serves as an integrative analytical bridge, enabling clearer traceability between legal requirements, sector-specific operational realities, and the mechanisms required to progress toward mature and harmonised NIS 2 compliance.

Discussions

In the absence of publicly disclosed cyber incidents in the European critical rail infrastructure post implementation of NIS 2, the ENISA Technical Implementation Guidance for Railway Cybersecurity (European Union Agency for Cybersecurity (2026)) offers an insight into current sector-wide implementation challenges. It serves as a crucial bridge between the directive’s regulatory expectations and the operational realities of critical rail infrastructure. It translates legal obligations into actionable steps, offering a structured pathway for harmonisation, capacity building, and resil-

Table 1 Article 21 of NIS 2 in critical rail infrastructure

NIS 2 Requirement (Art. 21)	Observed Status in Critical Rail Infrastructure	Identified Gaps	Mitigation/Recommendations	Supporting Frameworks
21(2)(a) – Risk analysis & security policies	Risk assessments conducted but vary greatly across operators; maturity uneven	Fragmented governance; inconsistent methodologies; limited OT visibility	Harmonised risk assessment aligned with TS 50701	ENISA Railway Cybersecurity CER risk obligations TS 50701 guidance
21(2)(b) – Incident handling (prevention, detection, response)	Incident handling procedures exist but differ widely. Detection remains weak in OT	Long detection times, supplier blind spots, limited forensic capabilities	Improve OT monitoring Supplier incident playbooks	ENISA Transport Landscape TS 50701 guidance
21(2)(c) – Business continuity (BCP) & disaster recovery (DR)	Strong physical BC/DR Cyber BC/DR is still emerging	Cyber scenarios are not well integrated Recovery planning is weak for OT	Include cyber-physical cascading scenarios in BC/DR exercises	CER continuity requirements; ENISA Cybersecurity Good Practices, TS 50701 guidance
21(2)(d) – Supply-chain security	Heavy reliance on suppliers. limited oversight of component-level security	No visibility into supplier cybersecurity maturity Dependency risks	Supplier cybersecurity assurance; CRA-aligned procurement	CRA ENISA Supply Chain TL TS 50701 guidance
NIS 2 Requirement	Observed Status in Critical Rail Infrastructure	Identified Gaps	Mitigation/Recommendations	Supporting Frameworks
21(2)(e) – Security in acquisition & development	Procurement primarily business/cost driven Security is not embedded early	“Secure-by-design” rarely required; inconsistent specifications	Introducing CRA-aligned secure development requirements in procurement	CRA lifecycle security TS 50701 secure development practices
21(2)(f) – Policies on crypto use	Use of cryptography varies legacy OT often cannot support strong crypto	Outdated protocols in OT systems key management gaps	Crypto lifecycle management	ENISA technical implementation guidelines TS 50701 cryptography guidance
21(2)(g) – Human resources security & training	Some cyber awareness programs exist, but OT workforce lacks specialised training	Skills shortages; inconsistent training coverage	Targeted OT cybersecurity training Joint CERT rail workshops	ENISA technical implementation guidelines TS 50701 competence requirements

Table 1 (continued)

21(2)(h) – Access control & asset management	IT asset inventories good; OT inventories incomplete or outdated	Fragmented tool ownership; no unified asset register	Integrated IT/OT asset management; passive discovery tools	ENISA technical implementation guidelines TS 50701 asset management
21(2)(i) – Vulnerability handling	Patch processes established for IT but slow in OT	Inability to patch safely Dependency on suppliers for patches	Risk-based OT patching Compensating controls Supplier patch SLAs	CRA mandatory vulnerability handling; ENISA cybersecurity good practices

Table 2 Article 23 of NIS 2 in critical rail infrastructure

NIS 2 Requirement (Art. 23)	Observed Status in Critical Rail Infrastructure	Identified Gaps	Mitigation/Recommendations	Supporting Frameworks
24-h early warning	Operators are aware of requirement, but detection delays prevent timely notification	Late classification; limited OT visibility	Improve detection. pre-defined reportability criteria	ENISA technical implementation guidelines TS 50701 guidance
72-h incident notification	Most operators meet formal deadline	Report content is often incomplete, as impact is not fully assessed	Strengthen forensic readiness	TS 50701 CER reporting alignment
One-month final report	Reports submitted but vary in quality	Limited detail on root cause and cascading impacts	Standardised templates Sector peer-sharing mechanisms	TS 50701 guidance
Report content (Article 23(4))	Technical details sparse due to supplier dependency and confidentiality	Operators lack information from vendors, so have incomplete evidence	Supplier reporting obligations should be enforced Contractual information-sharing clauses should be enforced	CRA ENISA threat landscape for supply chain attack

ience enhancement. Significantly, the themes emerging from this study align closely with the gaps highlighted in ENISA's technical recommendations, thereby reinforcing the validity of the empirical findings.

Firstly, the findings indicate that governance fragmentation remains one of the structural weaknesses in critical rail infrastructure. This misalignment limits visibility across systems and constrains information sharing in relation to cyber incidents. ENISA's technical implementation guidance provides a mechanism to address this fragmentation by prescribing unified governance models, common decision-making structures, and standardised processes. It recommends cross-entity coordination, joint security steering committees, and shared risk assessment frameworks that align directly with NIS 2's emphasis on coordinated risk management. Thus, while the findings expose fragmented governance, the ENISA framework offers a clear operational route to harmonise security management across critical rail infrastructure.

Secondly, ENISA's technical implementation guide recognises uneven cybersecurity maturity, particularly the gap between IT and OT security practices echoes the uneven implementation identified in both inductive and deductive coding results. The guidance notes that many operators lack mature asset inventories, risk assessment capabilities, and OT-specific security controls, further validating the conclusion that Article 21 compliance remains partial and highly variable across the sector. While IT environments in critical rail infrastructures in most cases have developed structured processes for asset management, monitoring, and risk assessment, OT systems continue to lag due to long asset lifecycles, proprietary architectures, and limited support for modern security interfaces. These observations correspond directly with both the inductive and deductive coding results, which identified partial implementation of Article 21 requirements, unclear asset ownership, inconsistent application of risk assessment frameworks, and dependency on suppliers for accurate vulnerability information. According to ENISA, these ongoing challenges largely stem from inherent complexities, such as the limited capacity for automated monitoring, responsibilities for maintaining asset inventories are distributed across different organisational units, and the diverse cybersecurity maturity levels among suppliers. Thus, the ENISA guidance not only validates the empirical themes of uneven implementation but provides an operational rationale for these gaps, demonstrating that Article 21 compliance challenges arise from structural rather than isolated issues. This alignment underscores that improving NIS 2 implementation in critical rail infrastructure requires targeted OT-focused measures, harmonised risk processes, and enhanced supplier assurance mechanisms each of which ENISA positions as essential for closing the IT–OT maturity divide.

Thirdly, ENISA highlights practical deficiencies in incident detection, forensic readiness, and crisis management integration, which aligns with this study's identification of persistent reporting challenges under Article 23. ENISA emphasises weak log correlation, insufficient monitoring, and the limited use of cybersecurity scenarios in exercises, suggesting that detection and reporting obligations remain aspirational rather than fully operationalised. The analysis also reveals inconsistencies in incident detection, reporting quality, and impact assessment. Although NIS 2 mandates structured timelines for notification early warning within 24 h, incident report within 72 h, and a final report within one-month operators still struggle with determining what qualifies as a notifiable incident, especially when dealing with OT disruptions, ambiguous impacts, or incomplete forensic data. These issues contribute to delayed reporting, underreporting, and difficulties producing reliable impact assessments. ENISA's implementation guidance addresses these gaps by providing operational reporting templates, incident categorisation schemes, severity indicators, and data quality requirements. These tools directly support operators in meeting Articles 21 and 23 by offering practical criteria for incident triage, evidence collection, forensic readiness, and cross-border information exchange. The contrast between the findings and ENISA's procedural recommendations highlights the need for further maturity-building in detection, classification, and impact evaluation processes within the critical rail infrastructure.

Finally, ENISA's detailed treatment of supply chain complexity strongly supports the study's findings on supplier dependency. ENISA notes that operators remain

heavily reliant on vendors for patching, updates, and lifecycle management, while procurement processes often fail to include standardised cybersecurity requirements. The findings underscore the vulnerability introduced by globalised critical rail infrastructure supply chains, where operators depend on suppliers with highly variable cybersecurity capabilities. Misalignment in security controls, limited oversight of third-party practices, and insufficient contractual requirements expose critical rail infrastructure cyber security risks, this aligns with analysis from NIS investment studies (European Union Agency for Cybersecurity (ENISA) (2025)). While physical resilience planning is comparatively mature, cybersecurity considerations remain under-integrated in continuity and crisis management processes. ENISA's implementation guides emphasises supplier assurance mechanisms, security-by-design in components, continuous lifecycle monitoring, and harmonised procurement standards. It also promotes contractual controls, supplier risk assessments, and the integration of cybersecurity into operational continuity plans. Thus, ENISA's operational direction provides a practical extension of NIS 2's supply chain obligations, demonstrating how regulatory requirements can be embedded into vendor management and system lifecycle processes.

The alignment between the findings and ENISA's operational recommendations suggests that while current implementation is uneven, the tools and frameworks necessary for significant improvement are already available. Strengthening coordination, standardising processes, and enhancing organisational capabilities will be central to achieving full compliance and building cybersecurity in European critical rail infrastructure.

RQ1: How is the critical rail infrastructure adopting and operationalising the requirements of the NIS 2 directive?

The findings indicate that adoption of NIS 2 within critical rail infrastructure remains partial and highly uneven, particularly in relation to Article 21. While operators have begun integrating risk management measures, asset inventories remain incomplete, OT systems lack mature security controls, and national-level variations hinder harmonised implementation.

RQ2: In what ways do rail-sector documents align with NIS 2 risk management and incident reporting requirements?

Document analysis of ENISA reports show partial alignment with NIS 2 expectations. While documentation demonstrates awareness of risk management needs, gaps persist in asset visibility, harmonised processes, accurate impact assessment, and cybersecurity considerations in crisis management. Incident reporting remains inconsistent and incomplete, particularly concerning OT systems resulting in only partial satisfaction of Article 21 and 23 obligations.

RQ3: What sector-specific challenges influence the ability to achieve effective NIS2 compliance?

Governance fragmentation, uneven maturity between IT and OT domains, dependency on suppliers, limited transparency, legacy system constraints, and cross-border operational structures all limit the capacity of critical rail infrastructure to meet NIS 2 requirements. These structural challenges mean that compliance depends not only on organisational readiness but on sector-wide coordination and supplier assurance, especially where NIS 2 interfaces with CER and CRA obligations.

Conclusion

This study examined how the European critical rail infrastructure interprets and operationalise the requirements of the NIS 2 directive, with particular emphasis on cybersecurity risk management, incident reporting, and the broader resilience obligations that intersect with the CER and CRA frameworks. Through inductive and deductive thematic analysis of ENISA reports the research generated a consolidated understanding of both current practices and structural challenges within critical rail infrastructure.

The findings demonstrate that while progress has been made toward integrating NIS 2 requirements, implementation remains partial, uneven, and constrained by sector-specific complexities. In addressing RQ1, the analysis showed that operators have begun translating NIS 2 into organisational procedures, yet persistent gaps in asset visibility, OT security, and harmonised risk management systems indicate an incomplete operationalisation of Article 21. In relation to RQ2, publicly ENISA documents exhibit partial alignment with NIS 2 expectations; however, inconsistencies in maturity levels, documentation quality, and incident impact assessment continue to impede effective compliance. Finally, the study responded to RQ3 by identifying structural barriers such as governance fragmentation, uneven cybersecurity capability across stakeholders, supply-chain complexity, and the challenge of securing legacy OT systems that collectively limit the sector's ability to achieve full NIS 2 conformity.

Taken together, the results illustrate that effective NIS 2 compliance within critical rail infrastructure cannot be achieved in isolation. Achieving regulatory alignment requires coordinated governance, strengthened supplier assurance consistent with CRA principles, and a sector-wide shift toward integrated IT/OT cybersecurity maturity.

Ultimately, this research contributes to the growing body of knowledge on European critical infrastructure cybersecurity by offering a practice-informed assessment of critical rail infrastructure's progress and persistent challenges. As the threat landscape evolves, continued alignment with NIS 2, CER, and CRA requirements supported by transparent reporting, harmonised frameworks, and robust supply-chain oversight will be essential to ensuring the cybersecurity of the European rail critical infrastructure.

Author contribution Mimi Enakome Oka (M.O)—Analysis, Writing, Edit, review Martin Hromada (M.H)—Conceptualization, Methodology, Edit, Supervision, Review Roman Jasek (R.J)—Resource provision, Edit, Review.

Funding Open access publishing supported by the institutions participating in the CzechELib Transformative Agreement.

Data availability The data used in this study are from publicly available documents.

Declarations

Ethics and consent Ethical approval and consents were not required.

Grant information This study did not receive grants from any funding agency, commercial entity, or non-profit organisations.

Competing interest The authors declare no competing interests.

Open Access This article is licensed under a Creative Commons Attribution 4.0 International License, which permits use, sharing, adaptation, distribution and reproduction in any medium or format, as long as you give appropriate credit to the original author(s) and the source, provide a link to the Creative Commons licence, and indicate if changes were made. The images or other third party material in this article are included in the article's Creative Commons licence, unless indicated otherwise in a credit line to the material. If material is not included in the article's Creative Commons licence and your intended use is not permitted by statutory regulation or exceeds the permitted use, you will need to obtain permission directly from the copyright holder. To view a copy of this licence, visit <http://creativecommons.org/licenses/by/4.0/>.

References

- Cigu E, Agheorghiesei DT, Gavriluță (Vatamanu) AF, Toader E (2018) Transport infrastructure development, public performance and long-run economic growth: a case study for the EU-28 countries. *Sustainability* 11(1):67. <https://doi.org/10.3390/su11010067>
- European Network and Information Security Agency (2020) Railway cybersecurity: security measures in the railway transport sector. LU: Publications Office. Accessed: Jan. 02, 2026. [Online]. Available: <https://data.europa.eu/doi/10.2824/235164>
- European Parliament and Council (2022) Directive (EU) 2022/2555 of the European Parliament and of the Council of 14 December 2022 on measures for a high common level of cybersecurity across the Union, amending Regulation (EU) No 910/2014 and Directive (EU) 2018/1972, and repealing Directive (EU) 2016/1148 (NIS 2 Directive). *Official J Eur Union* L 333: 80–152
- European Parliament, Council of the European Union Directive (EU) 2022/2557 of the European Parliament and of the Council of 14 December 2022 on the resilience of critical entities and repealing Council Directive 2008/114/EC
- European Union Agency for Cybersecurity (ENISA) (2021) Threat Landscape for Supply Chain Attacks. Publications Office of the European Union, Luxembourg, Rep. 601e6a13-f983-11eb-b520-01aa75ed71a1. <https://doi.org/10.2824/55355>.
- European Union Agency for Cybersecurity (ENISA) (2025) NIS Investments 2025 - Survey data companion document. ENISA, Athens, Greece. [Online].
- European Union Agency for Cybersecurity (2021) Railway cybersecurity: good practices in cyber risk management. LU: Publications Office. Accessed: Jan. 02, 2026. [Online]. Available: <https://data.europa.eu/doi/10.2824/92259>
- European Union Agency for Cybersecurity (2023) ENISA threat landscape: transport sector (January 2021 to October 2022) . LU: Publications Office, 2023. Accessed: Jan. 02, 2026. [Online]. Available: <https://data.europa.eu/doi/10.2824/553997>

- European Union Agency for Cybersecurity (2025) Technical implementation guidance on Commission Implementing Regulation (EU) 2024/2690 of 17 October 2024 laying down rules for the application of NIS2 Directive as regards technical and methodological requirements of cybersecurity risk-management measures: June 2025, version 1.0. LU: Publications Office. Accessed: Jan. 02, 2026. [Online]. Available: <https://data.europa.eu/doi/10.2824/2702548>
- A. Gabriel, F. Brauner, A. Lotter, and F. Fiedrich, “Cyber security flaws and deficiencies in the European Rail Traffic Management System towards cyber- attacks,” 2018.
- Harvey J, Kumar S (2020) A survey of intelligent transportation systems security: challenges and solutions. In: 2020 IEEE 6th Intl Conference on Big Data Security on Cloud (BigDataSecurity), IEEE Intl Conference on High Performance and Smart Computing, (HPSC) and IEEE Intl Conference on Intelligent Data and Security (IDS), Baltimore, MD, USA: IEEE, pp. 263–268. <https://doi.org/10.1109/BigDataSecurity-HPSC-IDS49724.2020.00055>.
- Ibadah N, Benavente-Peces C, Pahl M-O (2024) Securing the future of railway systems: a comprehensive cybersecurity strategy for critical on-board and track-side infrastructure. *Sensors (Basel)* 24(24):8218. <https://doi.org/10.3390/s24248218>
- Kun E (2025) Searching for the appropriate legal basis for personal data processing for cybersecurity purposes under the NIS 2 directive: legal obligation and/or legitimate interest? *Comput Law Secur Rev* 56:106098. <https://doi.org/10.1016/j.clsr.2024.106098>
- Mattioli G, Roberts C, Steinberger JK, Brown A (2020) The political economy of car dependence: a systems of provision approach. *Energy Res Soc Sci* 66:101486. <https://doi.org/10.1016/j.erss.2020.101486>
- Parkinson HJ, Basher DR, Bamford G Railway cyber security and TS50701. Presented at the The Fifth International Conference on Railway Technology: Research, Development and Maintenance, Montpellier, France, pp. 1–9. <https://doi.org/10.4203/ccc.1.17.1>.
- Predescu SG, Savu D, Badea VE (2022) Cybersecurity in the railway sector. *Romanian Cyber Security Journal* 4(2):95–104. <https://doi.org/10.54851/v4i2y2022010>
- “Regulation (EU) 2024/2847 of the European Parliament and of the Council of 23 October 2024 on horizontal cybersecurity requirements for products with digital elements and amending Regulations (EU) No 168/2013 and (EU) No 2019/1020 and Directive (EU) 2020/1828 (Cyber Resilience Act) (Text with EEA relevance)”.
- Ruohonen J (2024) A systematic literature review on the NIS2 directive. arXiv: arXiv:2412.08084. <https://doi.org/10.48550/arXiv.2412.08084>.
- Soderi S, Masti D, Lun YZ (2023) Railway cyber-security in the era of interconnected systems: a survey. *IEEE Trans Intell Transp Syst* 24(7):6764–6779. <https://doi.org/10.1109/TITS.2023.3254442>
- Zgorzelski R, Murawski J, Chamier-Gliszczyński N (2025) Digital technologies and cybersecurity of transport infrastructure: challenges for rail transport. *Arch Transp* 75(3):141–158. <https://doi.org/10.61089/aot2025.yfgz9c91>

Publisher's Note Springer Nature remains neutral with regard to jurisdictional claims in published maps and institutional affiliations.

Authors and Affiliations

Mimi Enakome Oka¹ · Martin Hromada¹ · Roman Jasek¹

✉ Mimi Enakome Oka
oka@utb.cz

Martin Hromada
hromada@utb.cz

Roman Jasek
jasek@utb.cz

¹ Tomas Bata University, Zlin, Czech Republic